DPDP Act 2023 & HIPAA Medical Data Privacy Audit Report

1. Executive Compliance Summary

Audit conducted by IT Security & Legal on the data migration pipeline from LegacyCare to NovaShield Health. Employee medical history, diagnosis codes (ICD-10), and dependent Aadhaar/DOB details classify as Sensitive Personal Data under India's DPDP Act and HIPAA standards.

2. Mandatory Zero-Trust & Row-Level Security Controls

1. Raw dependent medical claim reasons must never be exposed to Department Managers outside HR Benefits.
2. AI assistants querying company databases must enforce PostgreSQL Row-Level Security (RLS) so Lower-layer employees can only query their own `user_id` enrollment records.
3. Nightly census sync CSVs must mask Aadhaar digits (XXXX-XXXX-1234) prior to SFTP/API transmission.